

MediKiosk

Security, Data Privacy, HIS & ABDM Integration Plan

SIH 2026 · SIH26047 · Team DEBUGGERS

How MediKiosk handles patient data legally and technically, how it connects to the hospital's HIS (Bahmni), and how it fits into India's ABDM national health-data network — from zero to a working hackathon build.

Contents

1. Three Separate Things — Do Not Blur Them

These three concepts are related but distinct, and confusing them is the most common mistake teams make when pitching this kind of system.

- **Security & Data Privacy** — how MediKiosk protects patient data legally (DPDP Act) and technically (encryption, access control). Applies regardless of any hospital system.
- **HIS (Hospital Information System)** — the hospital's own record-keeping software, in this case Bahmni. This is where the finalized clinical record permanently lives.
- **ABDM (Ayushman Bharat Digital Mission)** — the national network layer that lets one hospital's HIS exchange records with another hospital's HIS, using ABHA IDs and FHIR-formatted data.

The flow: MediKiosk captures data → hands a clean draft to the clinician → once attested, pushes it into the HIS → the HIS (if it holds ABDM/HIP certification) can then exchange it nationally.

Key architectural correction

MediKiosk itself does NOT talk to the national ABDM gateway directly in a real deployment. The HIS does. This is the single biggest correction from the team's own research: earlier drafts assumed MediKiosk executes the full ABDM flow directly — the buildable, defensible position is that MediKiosk hands off a compliant FHIR bundle to the HIS, and the HIS's own ABDM-certified module handles the national exchange.

2. Security & Data Privacy — DPDP Act 2023 + 2025 Rules

2.1 Legal roles

Role	Who this is for MediKiosk
Data Principal	The patient — the individual whose data is processed.
Data Fiduciary	The hospital / AIIA — NOT the MediKiosk software vendor, unless the deployment contract says otherwise. This must be resolved explicitly in any real deployment.
Data Processor	MediKiosk software, cloud hosting provider, and any AI API vendor typically sit here.
Consent Manager (DPDP)	A separate registered entity managing consent across fiduciaries; registration opens Nov 2026. Distinct from ABDM's own Consent Manager concept.

Significant Data Fiduciary	A heightened-obligation category (DPO, impact assessments) — whether a hospital deploying MediKiosk at scale qualifies depends on volume/sensitivity thresholds still to be confirmed against final Rules.

2.2 Consent standard

Consent must be: free, specific, informed, unconditional, and unambiguous, with a clear affirmative action — and must be at least as easy to withdraw as it was to give.

- **Affirmative action:** an explicit tap or spoken “yes” — never a pre-checked box, implied consent from proceeding, or silence-as-consent.
- **Specific & itemised:** separate consent for distinct purposes (e.g. “consent to collect history for this consultation” is different from “consent to retain data for model-improvement research”). Bundling unrelated purposes is a known DPDP violation pattern.
- **Easy withdrawal:** a real withdrawal action available later, with a defined effect on already-collected data.
- **Layered consent:** essential processing (needed for the consultation) and non-essential processing (analytics/model training) presented as separable choices.

2.3 Notice requirements

Before or at the time of seeking consent, the patient must be told: what personal data is being collected, the specific purpose, and how to reach the data fiduciary about their data. The notice must be available in English or a language listed in the Act’s Eighth Schedule, at the patient’s choice — and must be delivered audibly, not just as on-screen text, for it to work for a low-literacy population. This is why Module A’s voice-first design is a compliance requirement, not a UX nicety.

2.4 Special populations & the emergency exception

- **Children & persons with disabilities:** verifiable parental/guardian consent required — must be an explicitly captured and verified relationship, not a checkbox.
- **Medical emergency exception:** the Act’s “legitimate use” category permits processing necessary for a medical emergency without prior consent. This may justify capturing the minimum data needed to raise a red-flag alert before consent completes — but every use of this exception must be logged and auditable, precisely because it is an exception, not a default.

2.5 Patient rights & grievance redress

1. Right to access information about how their data is processed.
2. Right to correction and erasure of personal data.

3. Right to nominate another person to exercise these rights on the patient's behalf in case of death or incapacity.
4. Right to effective grievance redress — a real, staffed contact path, not a dead-end form.

2.6 Retention, deletion & breach obligations

“Ephemeral local processing” is a design intent, not a retention schedule. A defensible specification requires an explicit, documented retention period for each data category, each with its own deletion trigger:

Data category	Notes
Raw audio	Delete promptly after transcription unless retained for a stated, consented purpose.
Scan images (prescriptions/labs)	Processed in memory; define exact deletion point.
Intermediate OCR output	Transient — define deletion trigger.
Draft summary (pre-attestation)	Hospital-side only, not exchanged; define retention window.
Clinician-attested final record	Becomes part of the permanent hospital record — retention follows the hospital's own medical-records obligations, which may be longer than MediKiosk's own needs.
Audit logs & backups	Standing retention per compliance policy, not ad hoc.

A breach-response plan (detection, containment, notification to the Data Protection Board and affected patients, forensic logging, recovery) is a standing requirement to have documented — not something to draft only if something goes wrong.

2.7 Build order for the hackathon window

1. Consent + notice screen (voice + visual, itemised, affirmative tap) — cheap to build correctly, and a strong first-impression trust signal for the jury.
2. A one-line-per-category retention table — even if only documented in the deck, not fully implemented in code.

3. An audit log for every red-flag / emergency-exception use.
4. Encryption at rest (AES-256) and in transit (TLS) for anything stored, even in a local demo database.

3. HIS — Bahmni

3.1 What Bahmni is

Bahmni is an open-source Hospital Management System + EMR, built from three components integrated together:

- **OpenMRS** — the core EMR engine (patients, encounters, observations). Java backend. Exposes REST and FHIR APIs.
- **OpenELIS** — lab workflow and results management (a fork maintained by the Bahmni team).
- **Odoo** (or **Crater** in the lighter Bahmni-Lite variant) — billing, inventory, ERP.

These three sub-systems are connected via an ATOM Feed integration bus. The frontend is a client-side application (legacy AngularJS, with newer React micro-frontends such as `openmrs-module-ipd-frontend`) that calls the OpenMRS REST APIs.

3.2 Integration points for MediKiosk

- **Primary hook — OpenMRS REST API:** patient search/create, visit creation, encounter creation, observations. This is the main “push the summary to the HIS” integration point.
- **FHIR path — `openmrs-module-fhir2`:** community-maintained module supporting FHIR R4 (and DSTU3), translating between OpenMRS’s internal data model and FHIR resources, two-way (export and import). This is where the Module C attested output gets mapped before anything ABDM-related happens.
- **Existing ABDM module — `hipmodule.omod`:** from `BahmniIndiaDistro/ndhm-react`. Bahmni already ships a Health Information Provider (HIP) module, plus separate Docker services: `health-information-provider` (HIP backend), `health-information-user` (HIU backend), and `hiu-ui`. This means MediKiosk does not need to build ABDM plumbing from scratch — deploy Bahmni’s own HIP module and containers, configure them, and MediKiosk only needs to push a correctly-formed FHIR bundle into `OpenMRS/fhir2`.

3.3 Running Bahmni locally

- **Bahmni-Lite** (uses Crater instead of Odoo, far lighter) vs **Bahmni-Standard** — use Bahmni-Lite for a hackathon demo.
1. `cd bahmni-lite`
 2. Configure `.env` (stable, image tag 1.0.0) or `.env.dev` (latest/unstable) or your own `.env.local`
 3. Run `./run-bahmni.sh` (supports `start` / `stop` / `logs` / `pull` / `reset`), or directly: `docker`

compose up --env-file .env

4. For ABDM features: separately deploy hipmodule.omod and the fhir2 omod into OpenMRS's /opt/openmrs/modules/, then bring up the HIP/HIU/hiu-ui containers from the bahmnicovid19/* Docker Hub images.

3.4 Integration contract to define — don't skip this

"Push the summary to the hospital HIS" is not itself an interface contract. A real specification requires:

- The exact target HIS/A-HMIS system, identified by name and version.
- Authentication method — API key, OAuth, or mutual TLS.
- Message format and API endpoint ownership.
- Sandbox or staging environment availability for testing.
- Defined error codes and retry/idempotency behaviour, so a network blip doesn't create duplicate records.
- A reconciliation process for detecting and resolving any push that silently failed.

Note: AIIA's own A-HMIS deployment is described in published literature as ABDM- and FHIR/HL7-compliant — confirm this against AIIA's specific current documentation before stating it as settled fact in a proposal.

4. ABDM Integration

4.1 What it is

ABDM is a national gateway that brokers consent and routing between hospitals — HIPs (Health Information Providers, who hold data) and HIUs (Health Information Users, who request it). Critically, the gateway itself never sees or stores the actual clinical content.

4.2 The milestone framework (M1–M4) — corrected understanding

Milestone	What it means	Realistic for a hackathon MVP?
M1	ABHA ID creation/verification	Yes — implement directly (QR scan / Aadhaar OTP / mock).
M2 (HIP)	Hospital certified as a data holder	No — requires NHA sandbox testing + Safe-to-Host security audit. Use Bahmni's existing HIP module code, but going live needs hospital-side certification.

M3 (HIU)	Hospital certified as a data requester	No — same certification requirement as M2. Simulate against ABDM sandbox and disclose as simulated.
M4	Further data-exchange maturity	Out of scope entirely for now.

A single facility can hold both HIP and HIU roles, but this does not change the certification requirement above.

4.3 Technical pieces

- **APIs:** target ABDM V3, the current API generation. Legacy v0.5/v1.0 are deprecated — do not build against them.
- **Data format:** FHIR R4 with India-specific NRCES profiles (e.g. the OPConsultRecord profile). Generic FHIR is not the same as ABDM-conformant FHIR — the specific resource graph and profile conformance must be demonstrated (validated against a public FHIR R4 validator), not just asserted.

Fidelius encryption — why not just TLS

TLS only encrypts data between two directly connected endpoints. ABDM routes data through a central Gateway that brokers the exchange without needing to see the actual content — Fidelius is ABDM's end-to-end encryption protocol designed so the Gateway never has access to plaintext health data, even momentarily.

- The requesting party (HIU) generates a fresh Elliptic-Curve Diffie-Hellman (ECDH) keypair for each individual consent transaction.
- The data-holding party (HIP) encrypts the FHIR bundle using AES-256-GCM, with a key derived from that ECDH exchange.
- Only the requesting HIU, holding the matching private key, can decrypt the payload.
- This per-consent key freshness means a compromised key from one transaction never exposes any other transaction's data.

Implementation gotcha

Fidelius uses Curve25519 in a specific Short Weierstrass form with non-default curve parameters, which most standard cryptography libraries do not support out of the box. Teams implementing this for real (beyond a mocked demo) typically need a library allowing custom elliptic-curve parameter definitions — e.g. the 'elliptic' npm package in Node, or BouncyCastle directly in Java/.NET.

The critical layer boundary

This is the single most important architectural correction to earlier MediKiosk drafts: a pre-

consultation intake draft (Module C's unattested summary) is not automatically the same artifact as a completed, ABDM-exchangeable clinical consultation record. The NRCES OPConsultRecord profile represents an attested clinical artifact with mandatory authorship and status fields that a pre-review AI draft cannot honestly satisfy.

- The patient evidence layer and the intake draft layer (Module A/B/C output, pre-attestation) are stored hospital-side, locally, and are never pushed through ABDM.
- Only after a clinician's explicit attestation does the data become eligible for FHIR packaging into an OPConsultRecord-class Composition, and — where the hospital's own ABDM M2/HIP integration is live — shared through the network.
- Pre-attestation data may be internally represented as a QuestionnaireResponse linked via Provenance to the eventual attested Observations, but that QuestionnaireResponse itself is not the artifact exchanged nationally.

4.4 Sandbox & testing plan

- Use sandbox.abdm.gov.in for M1–M3 development and NHA functional testing — no production security audit required at sandbox level.
- Use only synthetic/mock patient data throughout development and demo — never real, identifiable patient data.
- State explicitly in the demo which parts of the flow are live-sandbox versus fully mocked. A jury familiar with ABDM's actual complexity will recognise an overclaimed “full production M3 integration” immediately — honest scoping reads as more credible, not less.

4.5 Offline & connectivity-loss handling

- Define what data may be captured and encrypted locally when ABDM/HIS connectivity is unavailable, with a bounded local-storage window and a controlled sync-and-retry process on reconnect.
- Re-check consent validity on reconnect — never assume it still holds after a long offline gap.
- Prevent duplicate submission on reconnect using idempotency keys per session/artifact, rather than relying on network behaviour alone.

5. End-to-End Integration Flow for MediKiosk

Data flow

1. Kiosk (Modules A/B/C) captures voice/touch intake and OCR'd documents.
2. Clinician reviews and explicitly attests the draft summary.
3. MediKiosk backend converts the attested record into an NRCES-profile FHIR bundle.
4. Bundle is pushed via the OpenMRS REST + FHIR2 API into Bahmni (creates Encounter/Observations in the HIS).
5. Bahmni's own HIP module (already deployed alongside Bahmni) handles: registering the care context with ABDM, responding to HIU consent-based data requests, and Fidelius-

encrypting any outgoing bundle.

6. MediKiosk's own responsibility ends at “successfully pushed to HIS + FHIR-valid.” The national ABDM exchange itself is the HIS's certified responsibility, not MediKiosk's.

5.1 Build order for the hackathon window

1. Consent/notice UI (cheap, high trust-signal).
2. Local queue-ID identity as the default, always-working fallback (ABHA QR/Aadhaar OTP as a secondary/enhanced path, never the assumed default).
3. The FHIR resource graph generated from one completed, clinician-attested demo record, validated against a public FHIR R4 validator — the single strongest technical proof point available.
4. A mocked ABHA QR-scan pathway and a mocked/sandbox M1 identity flow.
5. A simulated Fidelius-style handoff — a sequence diagram plus a working local ECDH/AES-256-GCM encrypt-decrypt demonstration, even if not fully wired to the live ABDM gateway.

5.2 Demo script

- **Golden path:** consent notice delivered and affirmed in the demo language → queue-ID or mock-ABHA identity capture → completed attested record converted live into a FHIR bundle → bundle validated on stage with the validator's pass result shown as JSON.
- **Failure path:** a simulated connectivity loss during the ABDM handoff step, showing the offline-capture-and-retry behaviour rather than a dead end — followed by a clear statement of exactly which parts of the flow shown were live versus simulated. This transparency is itself a credibility-building move with a technically literate jury.

Appendix — Detailed Explanations, Point by Point

This appendix expands every key term and concept used above into a standalone explanation, for quick reference without needing to re-read the full sections.

A.1 DPDP Act 2023 & 2025 Rules

- **What it is:** India's primary data protection law, similar in spirit to the EU's GDPR. Passed in 2023; substantive Rules notified 13 November 2025, with a phased compliance rollout through May 2027.
- **Why it matters here:** MediKiosk processes sensitive personal health data at the point of collection, before any hospital or national system touches it — so DPDP obligations apply to MediKiosk's own design from the very first screen, independent of ABDM.
- **Design implication:** build to full compliance now, even though the legal deadline is phased through 2027 — this is the standard any credible healthcare product should meet, and a strong point in a hackathon pitch.

A.2 Data Principal / Fiduciary / Processor / Consent Manager

- **Data Principal:** the patient. Equivalent to “data subject” under GDPR.
- **Data Fiduciary:** the entity deciding why and how data is processed — the hospital, not the software vendor by default.
- **Data Processor:** an entity processing data on the fiduciary's behalf — this is where MediKiosk-the-software, cloud hosts, and AI API vendors sit.
- **Consent Manager:** a distinct, DPDP-registered entity managing a person's consent across multiple fiduciaries — separate from ABDM's own Consent Manager concept, which operates specifically for health-data exchange under the ABDM framework.

A.3 HIS (Hospital Information System)

- **What it is:** the software system a hospital uses to manage patient records, appointments, billing, and clinical workflows — the digital equivalent of the hospital's full paper filing system, digitized.
- **Why MediKiosk needs one:** MediKiosk is a pre-consultation intake tool, not a permanent record system. Once a clinician attests a summary, it must live somewhere permanent and hospital-owned — that's the HIS.
- **Bahmni specifically:** chosen because it is open-source, free to deploy, already used in real hospital settings, and — critically — already has ABDM integration groundwork (the HIP module) that MediKiosk can build on rather than reinvent.

A.4 OpenMRS

- **What it is:** an open-source medical record platform that forms Bahmni's core EMR engine. Handles patients, visits, encounters, and clinical observations as its core data model.
- **Why it matters:** it's the system MediKiosk actually talks to via REST/FHIR APIs when

“pushing to the HIS” — Bahmni's other components (billing, lab) sit around this core.

A.5 FHIR (Fast Healthcare Interoperability Resources)

- **What it is:** an international standard (HL7 FHIR) for representing and exchanging healthcare data as structured “resources” (Patient, Observation, Condition, MedicationStatement, DocumentReference, etc.), each with a defined schema.
- **Why it's required:** both Bahmni's fhir2 module and ABDM's national exchange run on FHIR — it's the common language that lets MediKiosk's structured intake become something both the hospital's own system and the national network can understand.
- **FHIR R4 vs India-specific profiles:** FHIR R4 is the base standard; ABDM requires that base standard used according to NRCES's specific Indian implementation guide (which resource fields are mandatory, which terminology codes are allowed). A FHIR bundle that is valid R4 but doesn't follow the NRCES profile will fail ABDM certification — so “we use FHIR” alone proves nothing without profile conformance.

A.6 ABDM (Ayushman Bharat Digital Mission)

- **What it is:** India's national digital health infrastructure initiative, aiming to give every citizen a unique digital health ID (ABHA) and enable secure exchange of health records across providers nationwide.
- **Core actors:** HIP (Health Information Provider — the hospital holding the data), HIU (Health Information User — the hospital or entity requesting it), and the ABDM Gateway (the routing/consent broker in between, which never sees the actual clinical content).
- **ABHA:** Ayushman Bharat Health Account — a patient's unique national health ID, used to identify and link their records across facilities.

A.7 M1–M4 Milestones

- **M1:** ABHA ID creation and verification — the identity layer. Achievable directly by MediKiosk.
- **M2:** HIP-side certification, allowing a facility to legally act as a data holder responding to requests. Requires NHA sandbox testing and a production security audit.
- **M3:** HIU-side certification, allowing a facility to legally request another facility's records. Same certification bar as M2.
- **M4:** further data-exchange maturity beyond basic HIP/HIU exchange — out of scope for this project's current stage.

A.8 HIP vs HIU

- **HIP (Health Information Provider):** the facility that currently holds a patient's data (e.g. the hospital where a past test was done).
- **HIU (Health Information User):** the facility requesting access to that data (e.g. the hospital the patient is visiting now).
- **Important nuance:** a single hospital can hold both roles at different times,

depending on whether it's providing or requesting data in a given exchange.

A.9 Fidelius Encryption

- **What it is:** ABDM's purpose-built end-to-end encryption protocol for health-data exchange, ensuring the central Gateway never sees plaintext clinical data.
- **How it works:** the HIU generates a fresh ECDH (Elliptic-Curve Diffie-Hellman) keypair per transaction; the HIP encrypts the FHIR bundle with AES-256-GCM using a key derived from that exchange; only the HIU's matching private key can decrypt it.
- **Why not just TLS:** TLS secures a direct connection between two endpoints, but ABDM's architecture routes through a Gateway as an intermediary — Fidelius ensures that intermediary is cryptographically blind to the content it's routing.

A.10 QuestionnaireResponse, Provenance, OPConsultRecord

- **QuestionnaireResponse:** a FHIR resource type suited to representing a structured, pre-attestation intake draft — answers to a set of questions, not yet a formal clinical record.
- **Provenance:** a FHIR resource that records the origin/history of a piece of data — used here to link a draft QuestionnaireResponse to the eventual attested Observations it informed.
- **OPConsultRecord:** the NRCES-defined FHIR profile representing a completed, attested outpatient consultation record — the artifact that is actually eligible for ABDM exchange, requiring mandatory authorship and status fields a pre-review AI draft cannot honestly claim.

A.11 Data Protection Board of India

- **What it is:** the regulatory authority established under the DPDP Rules 2025 to enforce the Act, receive breach notifications, and handle grievances.
- **Relevance:** MediKiosk's breach-response plan must route notification to this Board (and affected patients) as required — not an internal-only process.

A.12 Practical takeaway for the pitch

A jury evaluating this project — especially one from AIIA/Ministry of Ayush — will likely be more convinced by an honestly scoped system (“M1 live, M2/M3 simulated against sandbox, FHIR bundle validator-passed”) than by an overclaimed one (“full ABDM production integration”) that doesn't hold up under a technical question. The strongest, most defensible position is: DPDP-compliant by design from day one, HIS integration built on Bahmni's real REST/FHIR APIs, and ABDM readiness demonstrated at the sandbox level with a clear, explicit map of what's live versus simulated.